Détournement du PATH:

Cette variable d'environnement (PATH) spécifie l'ensemble des repertoires ou un exécutable peux être localiser
La création d'un script ou d'un programme dans un repertoir spécifié dans le PATH le rendra exécutable depuis n'importe quel repertoir du system ! a retenir
Ajouter au PATH d'un utilisateur ajoute son repertoir de travail actuel à la list
pour l'ajouter on peu faire PATH=.:$PATH puis export PATH par exemple on pe
y mettre un payload nommé ls qui s'executera à chaque fois que l'user taperas ls
C'est avec ce genre de petits skills qu'on aiguise ses competences pour developper de
CYBER WEAPON puissant !!!

Détournement de Wildcard:

Un caractère jocker peu être utilisé en remplacements d'autres caractères et est
interprété par le shell avant les autres actions
Voici des exemples de caractères jockers.
* Un asterisk qui peux correspondre à n'importe quel nombre de caractères da
un nom de fichier
? Correspond à un seul caractère n'importe lequel
[ ] Correspond à n'importe quel caractère définit entre les crochet à la position défi
exemple avec une commande pour comprendre ls doc[135].txt ou doc[0-9]
~ : un tild au début est remplacé par le nom du repertoir personnel de l'utilisateu
A nous de les connaitres pour detourner la logiques des taches crons mal codés ou au



Echapper Aux Shells Restreints:

Un shell restreint est un type de shell qui limite la capacité de l'utilisateur à
exécuter des commandes ca permet de fournir un environnement sur et controlé aux
utilisateurs qui pourraient endommager le system, intentionnellement ou accide
tellement parmi ceux-ci notons: (rbash), (rksh), (rzsh).
Plusieurs methodes peuvent nous permettre de potentiellement nous évader allant d
l'exploitation de vulnérabilité dans le shell lui même à l'utilisation de techniques cré
tivés pour contourner les restrictions mises en places
Quelques exemples: echo * au lieu de ls ou pour lire: while read i; do echo "$i"; done < file
1- Passer une commande 'echappé' en argument d'une valide: ls -l `pwd` ou
juste son exécution 'echapé': `pwd`
2- Bien sur on peux essayer les operateurs d'enchainement | ; && ||
3- En modifiant les variables d'environnement pour leur passer des commande
et les exécuter par leur appel ou bien en modifiant le repertoir courant de notre utilisateu
restreint
4- L'utilisation de fonctions shell, c'est un vecteur très intéressant.

Escalade de Privilège Basée sur les Permissions:

Permissions Spéciales:

La permission Set User ID upon Execution (Setuid) peut permettre à un utilis
teur d'exécuter un programme ou un script avec les permissions d'un autre utilisat
Le bit setuid apparait alors sous forme de s (-rwsr-...)
AgentPathGen@parrot ~$ find / -user root -perm -4000 2>/dev/null
On peu regarder si le binnaire est present dans GTFOBins ou le reverse pour trouver une
faille potentielle permettant une privesc

La permission Set-GroupID (setgid) est une autre permission qui nous permet d'execu
des binnaires comme si nous faisions partie du group qui les a créés Ils peuvent être explo
de la même maniere qu'avec setuid
AgentPathGen@parrot ~$ find / -uid 0 -perm -6000 -type f 2>/dev/null